

Enterprise AI Authentication Research • Part 2 of 7

Part 2

Tool Authentication & Connector Models

OAuth flows, SAML, OIDC, API keys, PATs, GitHub Apps, and Marketplace connectors

Enterprise Authentication & Identity Propagation for AI Agents

Overview

Enterprise AI agents connect to dozens of data sources and action surfaces. Each integration uses a distinct authentication mechanism — OAuth 2.0, SAML assertions, OIDC tokens, API keys, Personal Access Tokens (PATs), service accounts, GitHub Apps, or marketplace-installed apps. This section details the authentication model for each major connector category.

Connector Categories

- Source Code: GitHub, GitLab, Bitbucket
- Knowledge: Confluence, SharePoint, Google Drive, Notion
- ITSM: ServiceNow, Jira
- Communication: Slack, Microsoft Teams
- CRM: Salesforce
- Developer Platforms: Azure DevOps

Source Code Connectors

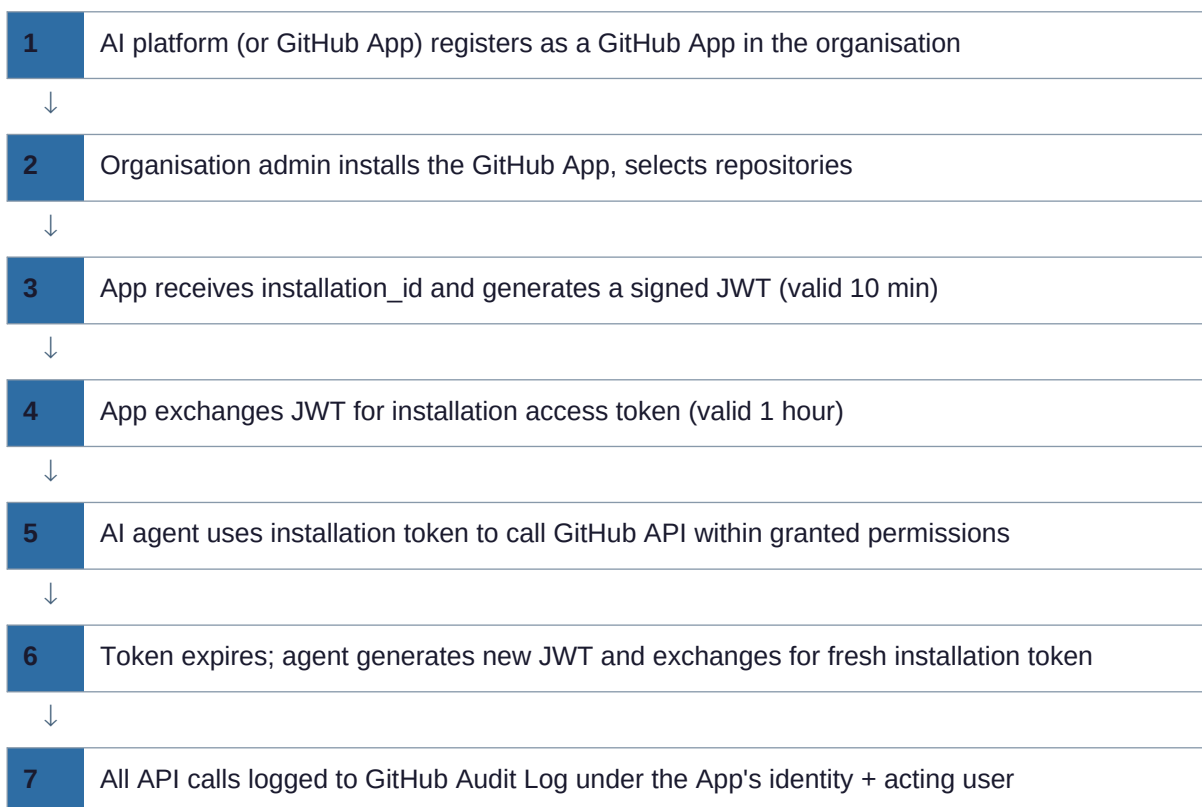
GitHub

GitHub offers three primary authentication mechanisms for AI connectors: OAuth Apps, GitHub Apps, and Personal Access Tokens. For enterprise AI agents, GitHub Apps are strongly preferred because they provide fine-grained, repository-scoped installation tokens that expire after one hour, eliminating long-lived credential risks.

GitHub Authentication Methods

Method	Scope Granularity	Token Lifetime	Best For	Audit Visibility
OAuth App	User-level scopes (coarse)	Token until revoked	User-delegated access	GitHub Audit Log
GitHub App	Fine-grained per-installation	Installation token: 1 h	AI agent integrations	Full org audit log
PAT (classic)	User-level, broad	Until expiry (max 1 yr)	Developer automation	Partial — no per-call log
Fine-grained PAT	Repository-scoped	Until expiry (max 1 yr)	CI/CD, limited automation	GitHub Audit Log
SAML SSO token	Requires org SAML auth	Session-based	Enterprise SSO enforcement	IdP + GitHub logs

GitHub App Authentication Flow



Identity Propagation: When a GitHub App acts on behalf of a user (e.g. creating a PR), it should use the user-to-server token flow: the user authorises the App via OAuth, and the App's API calls use the user's access token scoped to the App's permissions. This ensures GitHub records the acting user, not the App identity, in the commit or PR audit trail.

GitLab

GitLab Authentication Methods

Method	Scope	Lifetime	Notes
OAuth 2.0 (auth code)	Delegated user scopes	2 h access / refresh	Recommended for user-delegated AI access
Personal Access Token	api, read_user, etc.	Until revoked or expiry	Admin-managed; consider rotating
Project Access Token	Project-scoped	Until expiry	Best for single-project AI integrations
Group Access Token	Group-scoped	Until expiry	Enterprise multi-project agents
Deploy Token	read_registry, read_repository	Until revoked	CI/CD and read-only agents

Bitbucket

Bitbucket Authentication Methods

Method	Scope	Notes
OAuth 2.0 (Bitbucket Cloud)	Delegated user/account scopes	Access token (1 h) + refresh token
App Password	User-level granular permissions	Not tied to OAuth; no expiry; use with caution
Repository Access Token (DC/Server)	Repository-scoped	Available in Data Center; recommended
HTTP Access Token (Cloud)	Workspace / project / repo level	Replaces App Passwords for modern use

Knowledge Connectors

Confluence (Atlassian)

Confluence uses Atlassian's OAuth 2.0 3LO (Three-Legged OAuth) for delegated access and OAuth 2.0 (auth code grant) for service-to-service. AI connectors should use 3LO to act as the authenticated user, ensuring space and page permissions are respected. Service accounts should be used only for background indexing, not interactive retrieval.

Confluence Authentication Methods

Method	Use Case	Scopes	Limitation
OAuth 2.0 (3LO)	User-delegated read/write	read:page:confluence, write:confluence-content	Requires user consent per tenant
OAuth 2.0 (service)	Background crawling/indexing	read:confluence-space.summary, etc.	Acts as service account — no user context
Basic Auth (deprecated)	Legacy on-prem only	N/A	Not recommended; no token rotation
PAT (Data Center)	Automation on-prem	User-scoped	Supported in DC 7.9+; user context preserved

SharePoint / Microsoft 365

SharePoint authentication flows through Microsoft Entra ID. AI agents should use delegated (user) permissions via OAuth 2.0 OBO, never application permissions with site-wide access. The Microsoft Graph SharePoint API enforces site, list, and item-level permissions consistent with what the acting user can access in the SharePoint UI.

SharePoint Permission Models

Permission Type	Token Type	Access Level	AI Agent Recommendation
Delegated (user)	User access token via OBO	User's actual permissions	STRONGLY PREFERRED
Application (client credentials)	App access token	Tenant-wide or site collection	AVOID for interactive AI — over-privileged
SharePoint Add-in (legacy)	ACS token	App-only or user-combined	Deprecated — do not use for new integrations

Google Drive

Google Drive Authentication Methods

Method	Scope Examples	Use Case
OAuth 2.0 (auth code)	drive.readonly, drive.file	User-delegated AI access to Drive
Service Account + DWD	drive (impersonation)	Admin-level indexing (Domain-Wide Delegation)
Service Account (standard)	drive.readonly	Access only to files shared with service account
API Key	Public files only	No user context — not suitable for enterprise AI

Google Drive Security Warning

- Domain-Wide Delegation (DWD) grants service accounts access to ALL users' Drive data
- DWD should NEVER be granted to AI agent service accounts — use OAuth user delegation instead
- Restrict service account keys with IAM conditions; prefer Workload Identity Federation
- Audit service account key usage via Cloud Audit Logs: data_access log type

Notion

Notion Authentication Methods

Method	Scope	Notes
OAuth 2.0 (public integration)	Workspace-level read/write	User installs via OAuth; access limited to shared pages
Internal Integration Token	Workspace-scoped	Admin-created; no user context; needs explicit page share

ITSM Connectors

ServiceNow

ServiceNow provides multiple authentication mechanisms. For AI agent integrations, OAuth 2.0 with the Authorization Code grant is recommended for user-delegated actions. The client credentials grant is available for background service accounts. ServiceNow also supports mutual TLS for MID Server communications.

ServiceNow Authentication Methods

Method	Grant Type	User Context	Recommended
OAuth 2.0 Auth Code	Authorization Code	Yes (acting user)	Yes — for interactive AI actions
OAuth 2.0 Client Creds	Client Credentials	No (service account)	Background tasks only
Basic Auth	N/A	Yes (configured user)	No — insecure, no token rotation
SAML Bearer Assertion	JWT Bearer	Yes (asserted identity)	Enterprise SSO contexts
MID Server Certificate	mTLS	No (MID Server identity)	On-prem connectivity only

Jira (Atlassian)

Jira Authentication Methods

Method	Scope	Context	Notes
OAuth 2.0 (3LO)	read:issue:jira, write:issue:jira	Acting user	Preferred for AI agents
PAT (Data Center)	User-scoped	Acting user	Supported in DC 8.14+
API Token (Cloud)	User-scoped (basic auth)	User account	Acceptable; no OAuth flow
Connect App	Project-scoped	App identity or user	Marketplace connectors

Communication Connectors

Slack

Slack uses OAuth 2.0 for app authorization. AI connectors should be implemented as Slack Apps using the auth.v2 flow. Slack distinguishes between bot tokens (app identity) and user tokens (acting-user identity). For AI agents posting on behalf of users, user tokens with explicit consent are required to maintain identity transparency.

Slack Token Types

Token Type	Identity	Scopes	Use Case
Bot token (xoxb-)	App/Bot identity	chat:write, channels:read	Background notifications, app-driven posts
User token (xoxp-)	Specific Slack user	chat:write, users:read	Post as user — AI agent user delegation
App-level token (xapp-)	App identity (Socket Mode)	connections:write	WebSocket-based event handling

Microsoft Teams

Microsoft Teams Authentication Methods

Method	Identity	Scopes	Notes
Graph API (delegated)	Acting user via OBO	Chat.ReadWrite, ChannelMessage.Send	Preferred for AI agent messages
Graph API (application)	App identity	Chat.ReadWrite.All (admin consent)	Background bots; avoid for user delegation
Bot Framework	Bot identity	Bot-specific permissions	Conversational bots; not full API access
Teams Toolkit / Copilot Ext.	User or Bot	Plugin-specific scopes	Copilot Extensions manifest-defined

CRM Connectors — Salesforce

Salesforce uses OAuth 2.0 as its primary API authentication mechanism. For AI agents, the Web Server Flow (auth code + PKCE) is recommended for user-delegated access. Salesforce Connected Apps define the OAuth scopes and IP restrictions. JWT Bearer Flow is used for headless service-to-service integrations.

Salesforce OAuth Flows

Flow	User Context	When to Use	Security Notes
Web Server (Auth Code + PKCE)	Yes	Interactive user-delegated AI access	Recommended; PKCE prevents code interception
JWT Bearer (OAuth 2.0)	Asserted (pre-approved)	Background service agent	Requires admin pre-authorization per user
User-Agent Flow	Yes	Browser-based only	Deprecated; implicit flow security risks

Flow	User Context	When to Use	Security Notes
Client Credentials	No (service account)	System-to-system (no user)	Use only for non-user background tasks
Device Flow	Yes	CLI tools, kiosk	For environments without browser

Developer Platforms — Azure DevOps

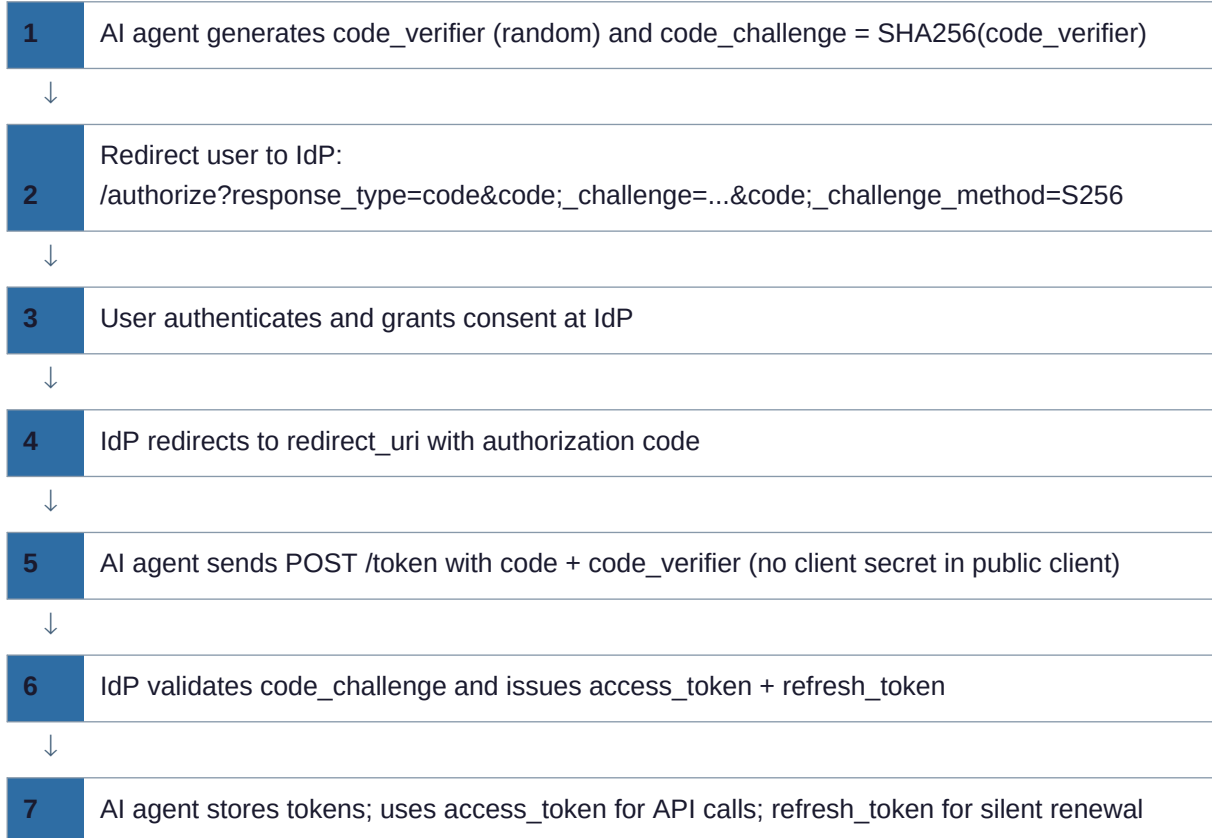
Azure DevOps Authentication Methods

Method	Identity	Scope	Notes
OAuth 2.0 (Entra ID)	User delegated	vso.code, vso.work	Preferred; integrates with Entra SSO
PAT	User identity	Granular per-feature	Easy to use; ensure rotation policy
Service Principal	App identity (Entra)	Service connection scopes	For CI/CD pipelines, not interactive AI
Managed Identity	Azure resource identity	As configured	Azure-hosted agents only; keyless

OAuth Flow Patterns for AI Connectors

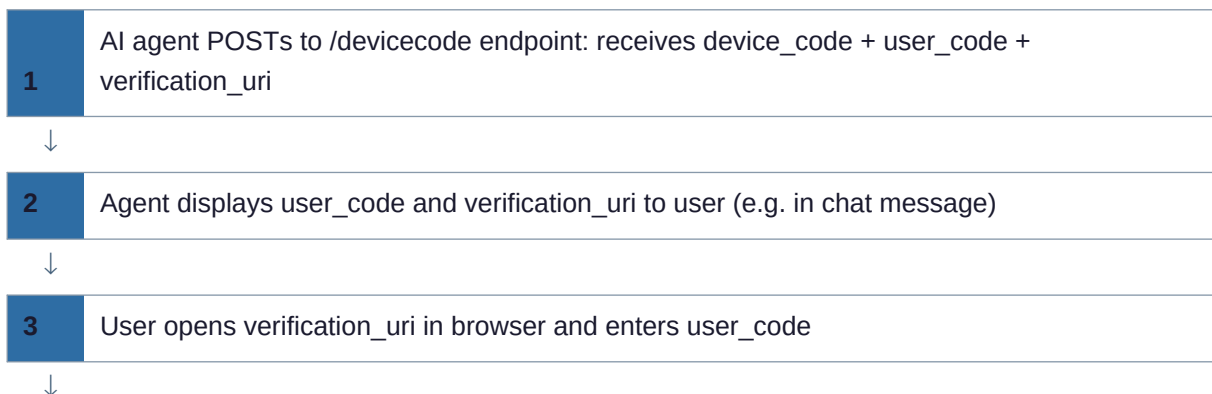
Authorization Code Flow with PKCE (Recommended)

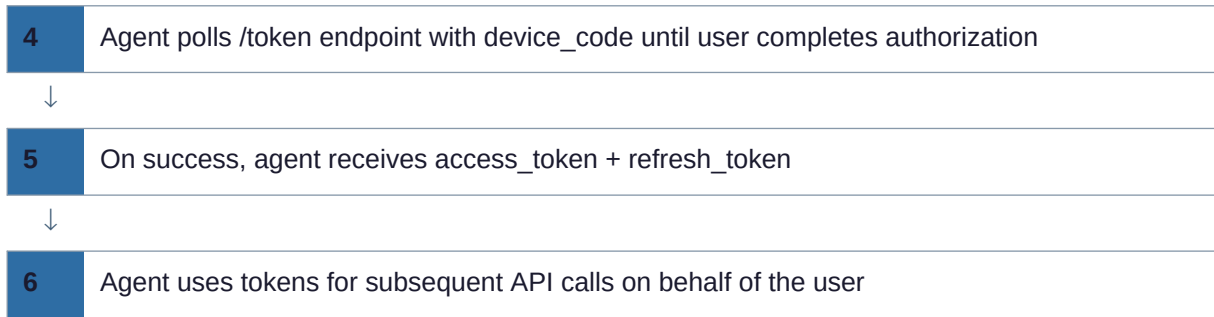
OAuth 2.0 PKCE Flow



OAuth 2.0 Device Flow (CLI / Headless AI)

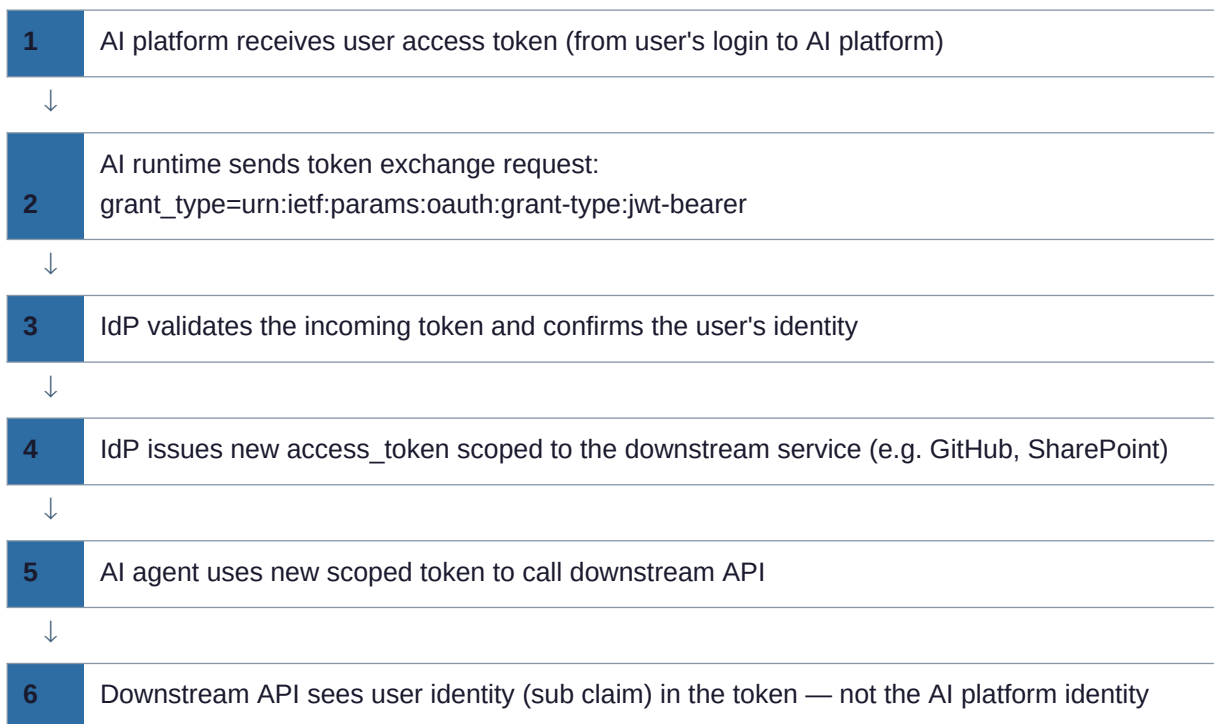
OAuth 2.0 Device Flow





JWT Bearer / On-Behalf-Of Flow

OAuth 2.0 On-Behalf-Of (OBO) Flow



Connector Authentication Summary

All Connectors — Authentication Summary

Connector	Recommended Method	User Context	Token Lifetime	Rotation
GitHub	GitHub App + user-to-server token	Yes	1 hour	Automatic
GitLab	OAuth 2.0 (auth code)	Yes	2 hours + refresh	Refresh token
Bitbucket	OAuth 2.0 or HTTP Access Token	Yes / Workspace	1 hour + refresh	Refresh token
Confluence	OAuth 2.0 (3LO)	Yes	1 hour + refresh	Refresh token
SharePoint	Graph API (OBO delegated)	Yes	60-90 min	Silent refresh / CAE
Google Drive	OAuth 2.0 (auth code)	Yes	1 hour + refresh	Refresh token
Notion	OAuth 2.0 (public integration)	Workspace	Until revoked	Manual rotation
ServiceNow	OAuth 2.0 (auth code)	Yes	30 min + refresh	Refresh token
Jira	OAuth 2.0 (3LO)	Yes	1 hour + refresh	Refresh token
Slack	OAuth 2.0 (user token)	Yes	Until revoked	Admin rotation
Teams	Graph API (OBO delegated)	Yes	60-90 min	Silent refresh / CAE
Salesforce	Web Server + PKCE	Yes	2 hours + refresh	Refresh token
Azure DevOps	OAuth 2.0 (Entra ID)	Yes	60-90 min	Silent refresh

Security Best Practices for Tool Authentication

- Always prefer OAuth 2.0 with PKCE over implicit flow or API keys
- Use GitHub Apps over OAuth Apps for granular, installation-scoped GitHub access
- Never use Domain-Wide Delegation (DWD) for interactive AI agent Google Drive access
- Store OAuth tokens encrypted at rest; use HSM or KMS-backed encryption
- Implement automatic refresh token rotation; treat refresh tokens as high-value secrets
- Use Continuous Access Evaluation (CAE) where available (Microsoft 365, Entra ID)
- Audit all token issuances and API calls; correlate with conversation/session IDs